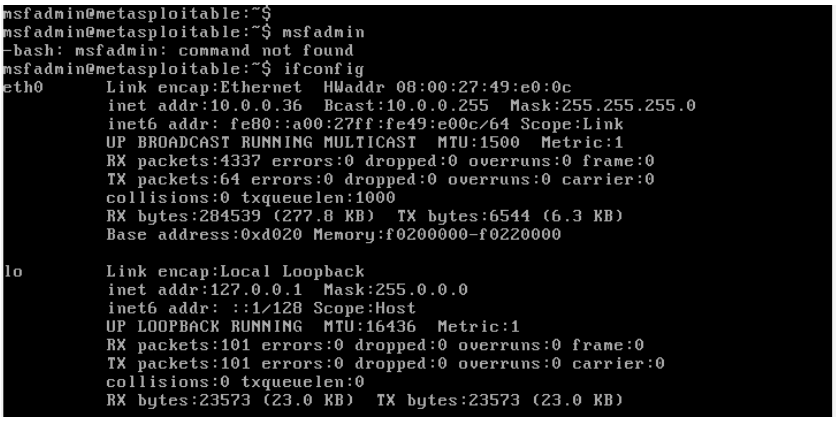
ACTIVIDAD 1.4
CIBERSEGURIDAD

Rodrigo Hernández Sánchez

Ejercicio 1. Identificar IP Metasploitable2, explica con precisión el significado del parámetro -sn y analiza todos los hosts encontrados en la red.

A) ¿Cuál es la dirección IP de tu Metasploitable2? ¿Te aparece al hacer escaneo con nmap?

Para saber la dirección IP de nuestro metasploitable2 debemos hacer uso del comando ifconfig, y después ver el apartado llamado “inet addr”, en este caso la IP es 10.0.0.36.



B) ¿Qué significa el parámetro -sn en Nmap?

El parámetro -sn activa el “ping scan”. Con él, Nmap hace solo el descubrimiento de hosts. Así sabrá qué equipos están encendidos y conectados a la red, y no escanea sus puertos.

Al utilizar este parámetro, le indicas a Nmap que realice únicamente el descubrimiento de hosts (determinar qué equipos están encendidos y conectados a la red) y que no intente escanear los puertos de dichos equipos.

En cuanto al analizar todos los hosts encontrados en una red, debemos hacer uso del comando nmap -sn 10.0.0.0/24 para que escanee todas las IPs alojadas en nuestra red.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 10.0.0.75/24

Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 06:14 -0400
Nmap scan report for 10.0.0.0
Host is up (0.97s latency).
Nmap scan report for 10.0.0.1
Host is up (0.0014s latency).
Nmap scan report for 10.0.0.2
Host is up (0.64s latency).
Nmap scan report for 10.0.0.3
Host is up (0.64s latency).
Nmap scan report for 10.0.0.4
Host is up (0.64s latency).
Nmap scan report for 10.0.0.5
Host is up (0.64s latency).
Nmap scan report for 10.0.0.6
Host is up (0.64s latency).
Nmap scan report for 10.0.0.7
Host is up (0.64s latency).
Nmap scan report for 10.0.0.8
Host is up (0.64s latency).
Nmap scan report for 10.0.0.9
Host is up (0.64s latency).
Nmap scan report for 10.0.0.10
Host is up (0.037s latency).
```

Ejercicio 2. Ejecuta ping correctamente, proporciona captura completa y clara, analiza los tiempos de respuesta y explica qué información revela sobre la conectividad.

A) ¿Qué indican los tiempos de respuesta obtenidos? ¿Qué información puedes deducir sobre la conectividad entre tu máquina y Metasploitable?

Usamos el comando ping con nuestra IP y nos revela la conectividad existente. La captura muestra el tiempo de respuesta a la recepción de los paquetes. Podemos observar que los tiempos de respuesta son bajos, eso es debido a que estamos en una red local.

```
┌──(kali㉿kali)-[~]
└─$ ping 10.0.0.36
PING 10.0.0.36 (10.0.0.36) 56(84) bytes of data.
64 bytes from 10.0.0.36: icmp_seq=1 ttl=64 time=1.08 ms
64 bytes from 10.0.0.36: icmp_seq=2 ttl=64 time=0.818 ms
64 bytes from 10.0.0.36: icmp_seq=3 ttl=64 time=0.684 ms
64 bytes from 10.0.0.36: icmp_seq=4 ttl=64 time=1.83 ms
64 bytes from 10.0.0.36: icmp_seq=5 ttl=64 time=0.847 ms
64 bytes from 10.0.0.36: icmp_seq=6 ttl=64 time=1.58 ms
64 bytes from 10.0.0.36: icmp_seq=7 ttl=64 time=1.23 ms
64 bytes from 10.0.0.36: icmp_seq=8 ttl=64 time=2.07 ms
64 bytes from 10.0.0.36: icmp_seq=9 ttl=64 time=2.16 ms

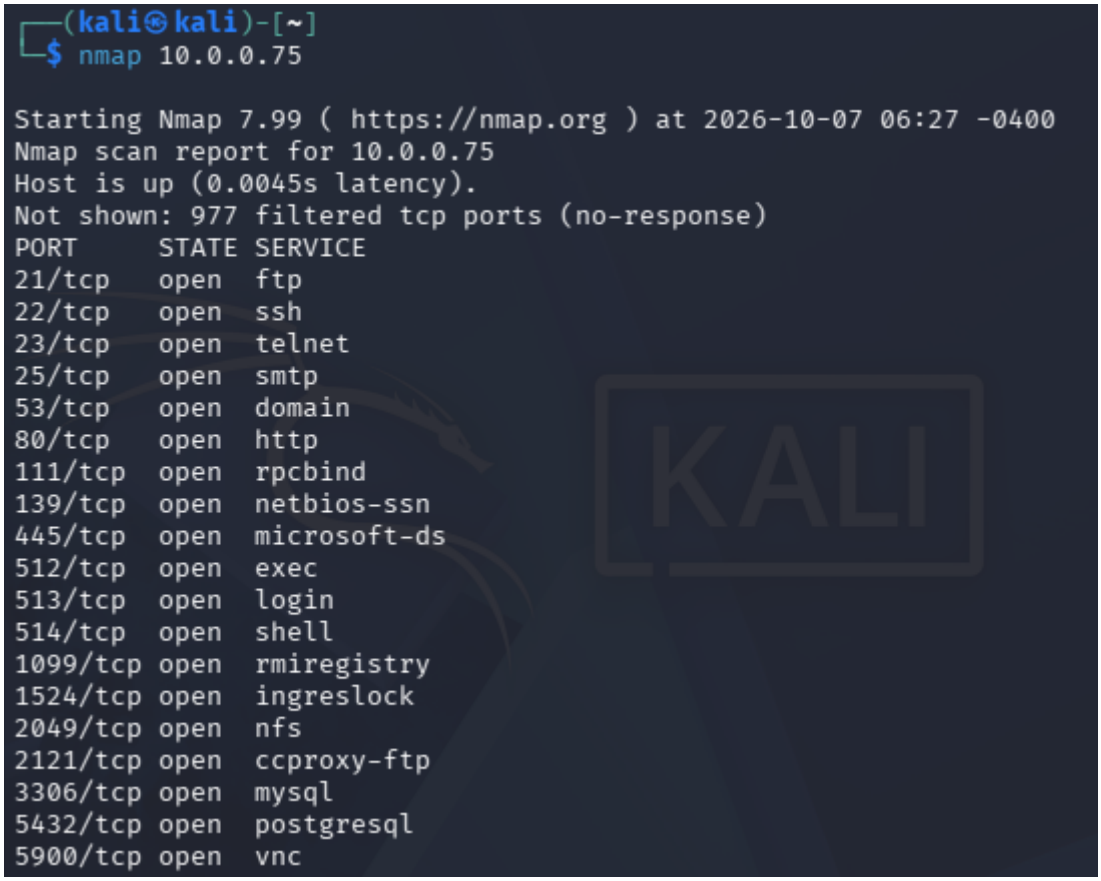
64 bytes from 10.0.0.36: icmp_seq=10 ttl=64 time=0.711 ms
64 bytes from 10.0.0.36: icmp_seq=11 ttl=64 time=2.12 ms
64 bytes from 10.0.0.36: icmp_seq=12 ttl=64 time=0.948 ms

64 bytes from 10.0.0.36: icmp_seq=13 ttl=64 time=0.743 ms
64 bytes from 10.0.0.36: icmp_seq=14 ttl=64 time=2.08 ms
64 bytes from 10.0.0.36: icmp_seq=15 ttl=64 time=0.876 ms
64 bytes from 10.0.0.36: icmp_seq=16 ttl=64 time=0.914 ms
64 bytes from 10.0.0.36: icmp_seq=17 ttl=64 time=0.878 ms
```

Ejercicio 3. Cuenta correctamente todos los puertos abiertos, identifica todos los servicios con precisión, proporciona capturas completas y analiza la relevancia de cada servicio encontrado.

A) ¿Cuántos puertos están abiertos en el escaneo básico?

Para observar qué puertos están abiertos deberemos hacer uso del comando nmap 10.0.0.X (la x será la IP obtenida en metasploitable).
Nmap hará un escaneo sobre la ip del equipo que le pasemos.
En nuestro caso encuentra 23 puertos abiertos con este escaneo básico.



B) ¿Qué servicios identifica Nmap automáticamente?

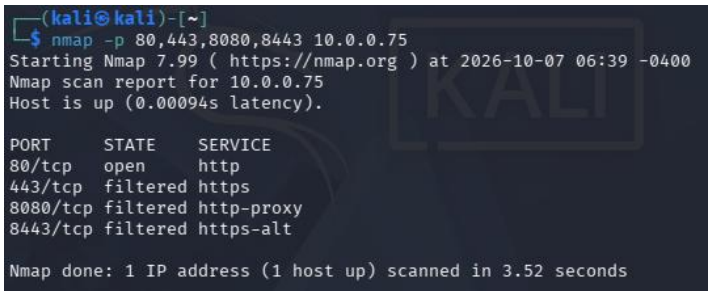
En el escaneo básico realizado con Nmap se han encontrado 23 puertos TCP abiertos. Nmap identifica automáticamente los servicios asociados a la mayoría de estos puertos, como FTP, SSH, Telnet, SMTP, DNS, HTTP, MySQL, PostgreSQL, VNC e IRC, entre otros.

Se observa que en el puerto 8180/tcp, Nmap no consigue identificar el servicio y lo muestra como unknown.

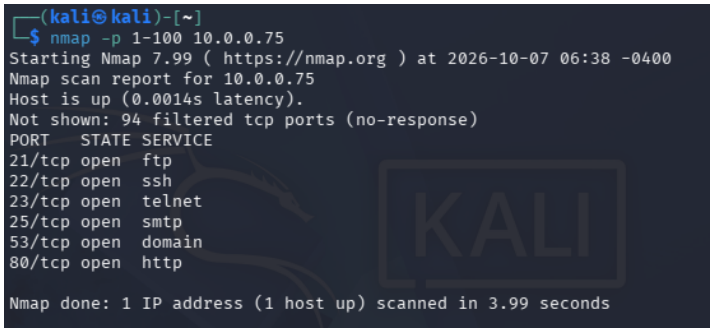
Ejercicio 4. Ejecuta ambos comandos correctamente, analiza tiempos de ejecución con precisión, compara resultados detalladamente, justifica la utilidad de escaneos dirigidos con ejemplos.

A) ¿Cuál de los tres comandos ejecutó más rápido? ¿Por qué crees que es así?

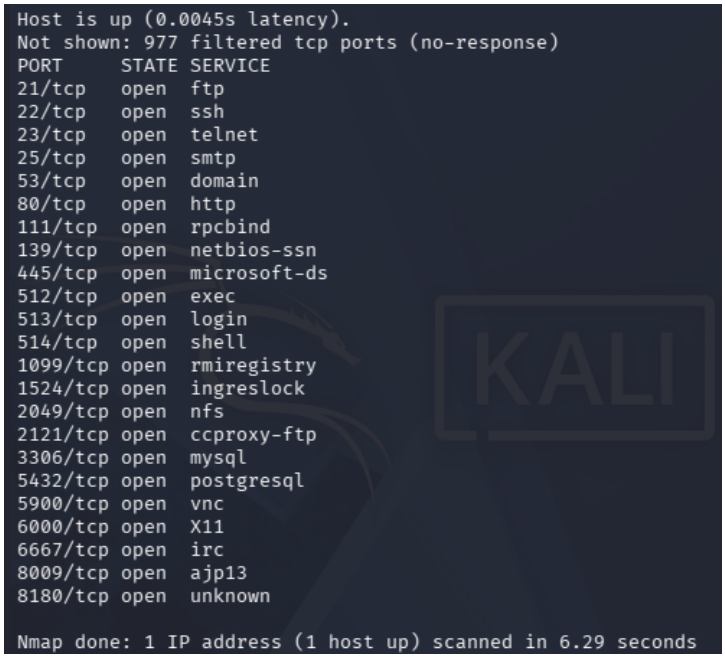
El comando más rápido fue nmap -p 80,443,8080,8443 10.0.0.75 que tardó 3,52 segundos**.**



El segundo fue nmap -p 1-100 10.0.0.75 que tardó 3,99 segundos**.**



Y por último nmap 10.0.0.75 que tardó 6,29 segundos**.**



El primero fue más rápido porque solo tuvo que analizar 4 puertos concretos, mientras que el segundo analizó 100 puertos y el escaneo básico analiza un conjunto mucho mayor de puertos habituales.

B) En el escaneo de puertos 1-100, ¿cuántos puertos abiertos encontraste comparado con el escaneo completo del ejercicio 3?

Se han encontrado 6 puertos abiertos:

21 → FTP

22 → SSH

23 → Telnet

25 → SMTP

53 → DNS

80 → HTTP

En el escaneo básico del ejercicio anterior encontramos 23 puertos abiertos.

Por tanto:

Escaneo 1-100 → 6 puertos abiertos
Escaneo básico → 23 puertos abiertos

C) ¿Por qué crees que es útil poder escanear rangos específicos de puertos?

Es útil poder escanear rangos específicos porque permite centrarnos en determinados puertos, reduciendo el tiempo de escaneo y facilitando el análisis de servicios concretos.

Ejercicio 5. Identifica el SO correctamente, lista 10+ servicios con versiones exactas, ejecuta ambos comandos correctamente, analiza implicaciones de seguridad de las versiones.

A) ¿Qué sistema operativo ejecuta Metasploitable2?

Metasploitable2 utiliza un sistema operativo basado en Linux/Unix. El escaneo de Nmap lo identifica como Unix/Linux y muestra que utiliza Samba sobre Debian.

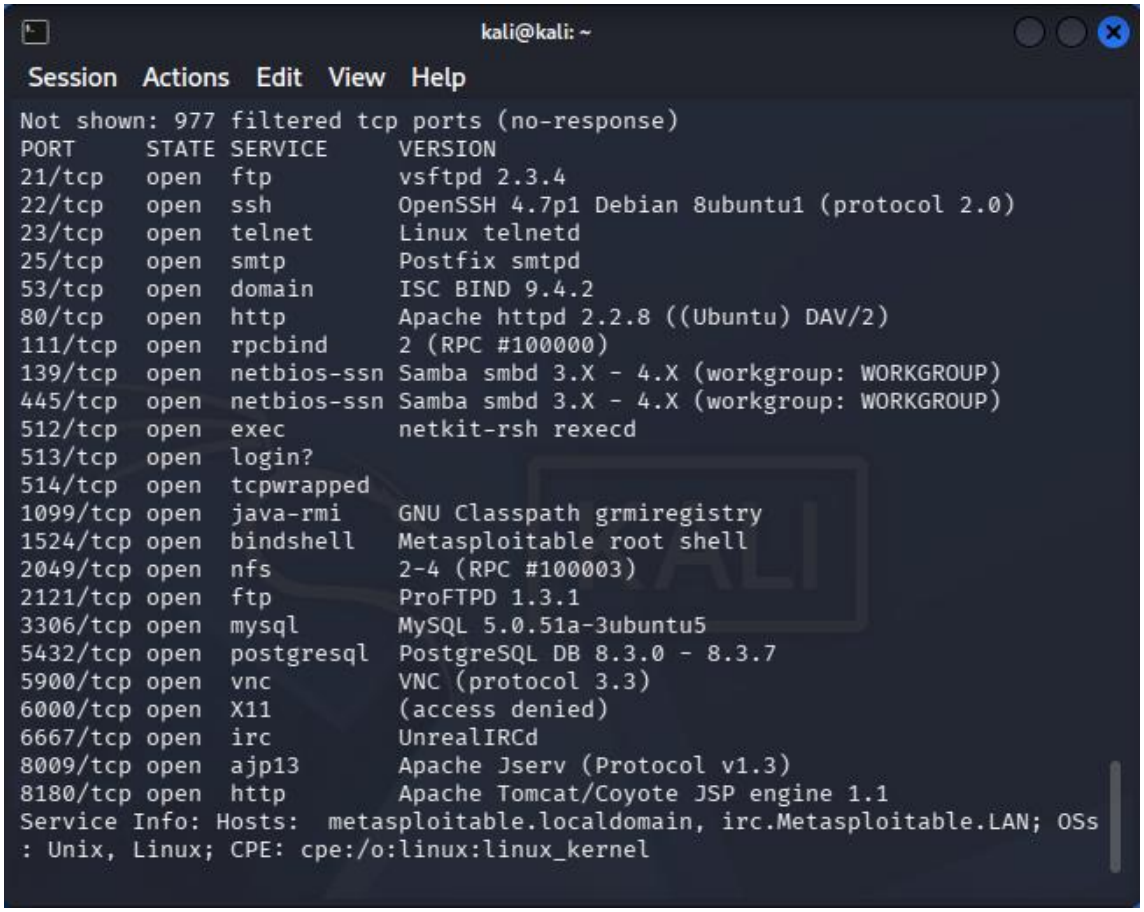


B) Lista los 10 servicios principales con sus versiones exactas.

Puerto	Servicio	Versión
21	FTP	vsftpd 2.3.4
22	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23	Telnet	Linux telnetd
25	SMTP	Postfix smtpd
53	DNS	ISC BIND 9.4.2
80	HTTP	Apache httpd 2.2.8 (Ubuntu)
139	Samba	Samba smbd 3.X - 4.X
445	Samba	Samba 3.0.20-Debian
2121	FTP	ProFTPD 1.3.1
3306	MySQL	MySQL 5.0.51a-3ubuntu5

Ejercicio 6. Ejecuta scripts correctamente, identifica todos los servicios en ejecución, interpreta advertencias de seguridad con precisión.

¿Qué servicios aparecen en ejecución en la máquina Metasploitable según la salida?



En la máquina Metasploitable2 aparecen los siguientes servicios: FTP, SSH, Telnet, SMTP, DNS, HTTP, RPCbind, Samba, exec, login, shell, Java RMI, una consola de acceso remoto, NFS, MySQL, PostgreSQL, VNC, X11, IRC, AJP13 y Apache Tomcat.

¿Qué versiones identifica nmap para al menos dos de esos servicios?

Nmap identifica:

- FTP: vsftpd 2.3.4, en el puerto 21.
- SSH: OpenSSH 4.7p1 Debian 8ubuntu1, en el puerto 22.
- DNS: ISC BIND 9.4.2, en el puerto 53.
- HTTP: Apache httpd 2.2.8 (Ubuntu), en el puerto 80.
- MySQL: MySQL 5.0.51a-3ubuntu5, en el puerto 3306.

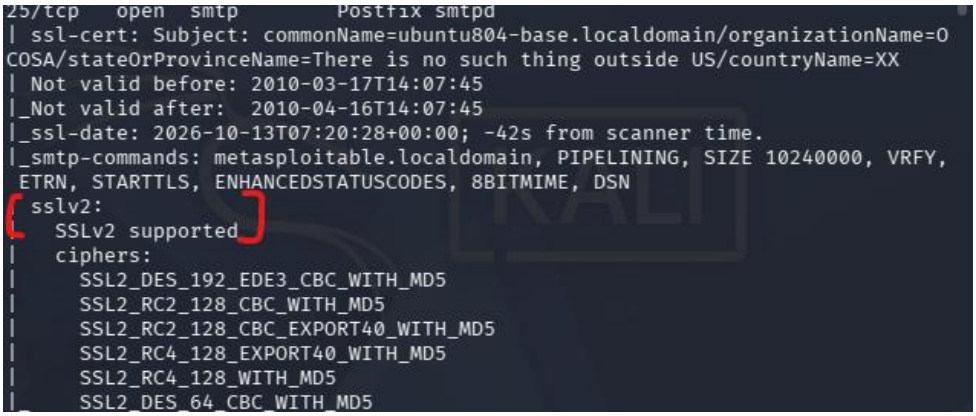
¿Hay algún servicio que muestre advertencias o mensajes de seguridad en la salida de los scripts? ¿Cuál y qué significa?

Sí. Aparecen varios mensajes relacionados con la seguridad.

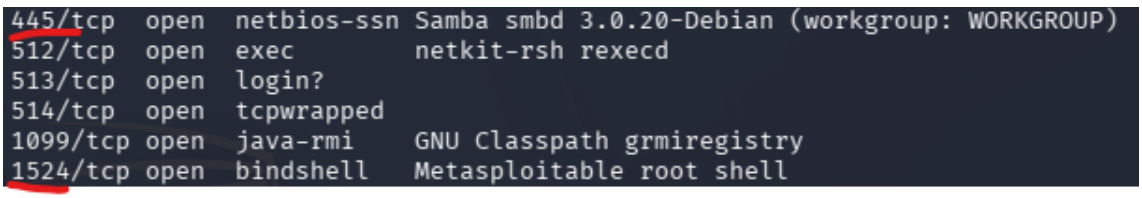
- *FTP (puerto 21) (Criticidad alta):* Nmap indica que se permite el acceso anónimo (Anonymous FTP login allowed). Esto significa que se puede acceder al servidor FTP sin utilizar una cuenta personal. (Supone acceder a archivos por cualquier persona, acceder a documentos sensibles y modificar archivos)



- *SMTP (puerto 25) (Criticidad media):* el servidor admite SSLv2, un protocolo de cifrado antiguo e inseguro que debería evitarse. (Supone la posibilidad de interceptar información, el robo de esta misma y la pérdida de privacidad).



- *Samba (puerto 445) (Criticidad media):* Nmap indica que la firma de mensajes está desactivada (message_signing: disabled). Esto puede aumentar el riesgo de ataques de intermediario en determinadas condiciones. (Supone que la firma de mensajes esta desactivada lo que podría llevar a la interceptación de comunicaciones y manipulación de datos).
- *Puerto 1524 (criticidad crítica):* Nmap identifica una consola de acceso remoto con permisos de administrador (Metasploitable root shell), lo que supone un riesgo crítico si el servicio es accesible por usuarios no autorizados. (Supone que se puede acceder a la consola mediante acceso remoto, lo que conlleva un acceso no autorizado, robo de información y modificación o eliminación de archivos).



Ejercicio 7. Ejecuta searchsploit correctamente para dos servicios diferentes, selecciona vulnerabilidad relevante y significativa, investiga CVE con detalle técnico, relaciona vulnerabilidad con riesgo real

Selecciona dos servicios que hayas encontrado con nmap, y búscalos con searchsploit. Adjunta su salida.

Utilizamos el comando searchSploit para buscar vulnerabilidades de dos servicios mostrados con nMap.

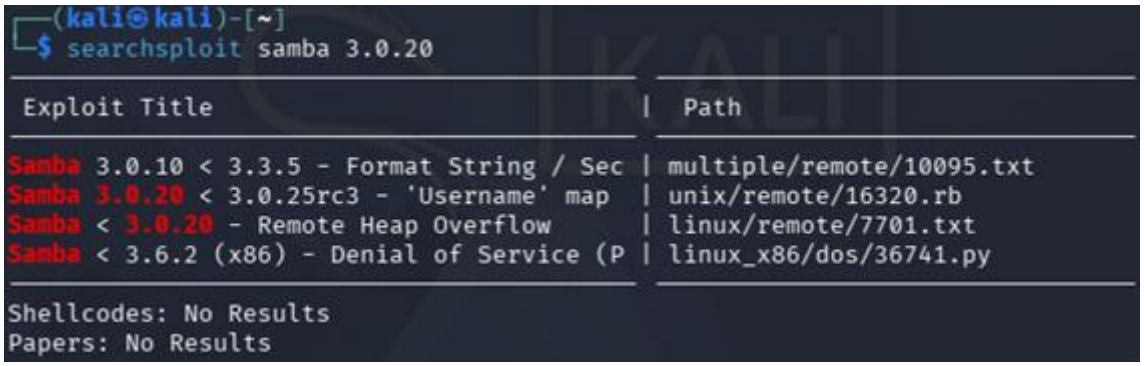
Usaremos vsftpd 2.3.4 y Samba 3.0.20 ya que salió al usar el comando nmap -sC -sV 10.0.0.37

En el primero, se muestran dos exploits, como resultado es “Backdoor Command Execution”.

(Ataque mediante una puerta trasera para sistemas Unix y remotos y finalmente el archivo del exploit está escrito en Ruby y Python).



En cuanto al segundo resultado aparece cuatro exploits detectados. Los tres primeros permiten comprometer el sistema y el último solo lo deja sin servicio. Elegimos el de ‘Username’ map script, que permite ejecutar comandos de forma remota.



A continuación, selecciona una de las vulnerabilidades que hayas visto, y busca su código CVE en Google.

https://www.cve.org/CVERecord?id=CVE-2007-2447

El código será CVE-2007-2447 (Samba “username map”).

Detalles:

- Afecta a Samba desde la 3.0.0 hasta la 3.0.25rc3. Nuestra máquina usa la 3.0.20, así que es vulnerable.
- Ocurre cuando en smb.conf está activada la opción username map script. No viene activada por defecto, pero sí en Metasploitable2.
- Samba pasa el nombre de usuario que envía el cliente a la shell sin filtrarlo. Si ese nombre incluye metacaracteres de shell (por ejemplo, comillas invertidas o ;), la shell ejecuta lo que haya dentro. Es una vulnerabilidad de inyección de comandos.
- El ataque se puede hacer desde la red, sin credenciales válidas, porque el nombre se procesa antes de comprobar la contraseña.
- El servicio smbd suele ejecutarse como root, así que los comandos se ejecutan con permisos de administrador.
- Se corrigió en Samba 3.0.25.

Ejercicio 8. Analiza con precisión el impacto en C, I y A por separado, justificado con el caso concreto, y propone una medida de mitigación coherente

Selecciona una de las vulnerabilidades del ejercicio 7 (o cualquier servicio detectado).

CVE-2007-2447 (Samba “username map”).

A) Si un atacante la explotara con éxito, ¿qué impacto tendría sobre la confidencialidad, integridad y disponibilidad del sistema?

Confidencialidad: El atacante podría acceder a información privada del sistema, como archivos o datos almacenados, si consiguiera los permisos necesarios. Esto supondría que información protegida quedara expuesta.

Integridad: El atacante podría modificar o eliminar archivos y alterar datos del sistema si consiguiera los permisos necesarios. Esto provocaría que la información pudiera dejar de ser correcta o fiable.

Disponibilidad: El atacante podría interrumpir el funcionamiento del servidor o de sus servicios, impidiendo que los usuarios los utilizaran con normalidad.

B) Justifica cada pilar por separado. ¿Qué medida de protección (sin necesidad de implementarla) reduciría este impacto?

Actualizar Samba a una versión corregida, revisar su configuración y limitar el acceso al servicio a los equipos autorizados. Esto reduciría el riesgo de explotación y sus posibles consecuencias.